

Identity and Access Management (IAM) Configuration

Prepared by: Omkar Sawant
Client: GlobalTech Corp
Date: 30 May 2026
Project: Implementing a Secure Network Architecture for a Large Enterprise
Organisation: Spinnaker Analytics

1. Purpose and Scope

- This document defines the Identity and Access Management configuration for GlobalTech Corp, covering multi-factor authentication (MFA) enforcement and role-based access control (RBAC) implementation across all user accounts and systems. It remediates Findings 10 and 12 from the Network Architecture Assessment Report (22 May 2026):
 - Finding 10: No MFA enforced — all user accounts including administrators relying on single-factor password authentication
 - Finding 12: Excessive user privileges — RBAC partially implemented, users retaining elevated access from previous role assignments
- This configuration applies to all approximately 580 user accounts across HQ Mumbai, Remote Office 1 (Delhi), Remote Office 2 (Bangalore), and remote employees.

2. IAM Architecture

- GlobalTech Corp's IAM is built on Microsoft Entra ID (formerly Azure AD) as the central identity provider
 - Integrated with on-premises Active Directory via Entra ID Connect.
- All authentication flows pass through Entra ID
 - enabling consistent MFA enforcement and conditional access policies across cloud and on-premises resources.

Component	Solution	Function
Identity provider	Microsoft Entra ID	Central IdP — SSO, MFA, conditional access
On-prem directory	Active Directory (Windows Server)	User and group management for domain resources
Directory sync	Entra ID Connect	Synchronises on-prem AD with Entra ID
MFA service	Microsoft Authenticator / FIDO2	Push notifications, TOTP, hardware keys
Privileged access	Entra Privileged Identity Management (PIM)	Just-in-time admin access, approval workflows
Access reviews	Entra Access Reviews	Automated quarterly access certification
ZTNA integration	Cloudflare Access + Entra ID	Identity-aware proxy for remote resource access

3. Multi-Factor Authentication (MFA) Configuration

3.1 MFA Requirements by User Tier

- MFA is mandatory for all user accounts without exception. The required MFA method varies by account privilege level, following a tiered approach:

User tier	Account type	MFA method	Fallback
Standard	All general employees	Microsoft Authenticator (push)	TOTP (backup codes)
Privileged	IT staff, team leads	TOTP authenticator app	Supervisor approval + TOTP
Administrator	System and domain admins	FIDO2 hardware security key (YubiKey)	Secondary FIDO2 key (registered)
Service accounts	Automated processes	Certificate-based auth (no human MFA)	Managed identity where possible
Guest / external	Contractors, partners	Microsoft Authenticator (push)	OTP via email (time-limited)

3.2 Conditional Access Policies

- Entra ID Conditional Access policies enforce MFA and access restrictions based on user context. The following policies are active:

Policy name	Condition	Action
Require MFA — all users	Any sign-in to any app	Require MFA — no exceptions
Block legacy auth	Auth using SMTP, POP3, IMAP, NTLM	Block — legacy protocols do not support MFA
Admin MFA — FIDO2 only	Sign-in with admin role	Require FIDO2 hardware key only
High-risk sign-in	Entra risk score = High (new location, suspicious IP)	Block + require password reset + MFA
Unmanaged device	Sign-in from non-compliant device	Require MFA + restrict to browser-only (no app access)
Finance system access	Access to Finance/HR applications	Require FIDO2 + compliant device + named location
Off-hours access	Sign-in outside 06:00–22:00 IST	Require step-up MFA + alert security team

3.3 MFA Registration and Rollout

- MFA registration is enforced through Entra ID's registration campaign:
 - All new employees must register MFA method within 24 hours of account creation
 - account is restricted until registered
 - Existing employees migrated via 14-day registration campaign
 - daily prompts to register, access restricted on day 15 if not complete
 - Administrators must register FIDO2 hardware key before admin role is assigned
 - no exceptions
 - MFA registration requires IT helpdesk verification of identity in person or via video call
 - prevents social engineering

3.4 FIDO2 Hardware Key Configuration

- YubiKey 5 Series keys are issued to all administrators and Finance/HR staff.
Configuration steps:

```
# Entra ID - enable FIDO2 security key method
Security > Authentication methods > FIDO2 security key
Enable: Yes
Allow self-service setup: No (IT-managed enrollment only)
Enforce attestation: Yes
Key restrictions: Allow only YubiKey AAGUIDs
```

- Each administrator is issued two YubiKey 5 NFC keys
 - primary and backup
- Keys are registered to the user account by IT via supervised enrollment session
- Lost keys must be reported within 1 hour
 - account locked, new key issued after identity re-verification

4. Role-Based Access Control (RBAC)

4.1 RBAC Design Principles

- **Least privilege**
 - every role grants only the minimum permissions required for the job function
- **Separation of duties**
 - no single role has permissions to both approve and execute sensitive operations
- **Role hierarchy**
 - permissions are inherited down the hierarchy; lower roles cannot exceed parent role permissions
- **No direct permission assignment**
 - all permissions granted through roles, never assigned directly to individual users
- **Quarterly access review**
 - all role assignments reviewed and re-certified every 90 days via Entra Access Reviews

4.2 Role Definitions

Role	Assigned to	Key permissions	Restrictions
Global Admin	Max 2 break-glass accounts	Full Entra ID control	FIDO2 only, PIM-gated, MFA always
IT Admin	IT operations staff	User mgmt, device mgmt, helpdesk	No direct data access, no billing
Security Admin	Security team	SIEM, EDR, firewall, alerts	Read-only on user accounts
Finance User	Finance department	Finance apps, Finance VLAN resources	No HR system access
HR User	HR department	HR apps, HR VLAN resources	No Finance system access
Standard User	All general employees	Email, SharePoint, standard apps	No server or admin access
Read-Only Auditor	External auditors, compliance	Read-only logs and reports	No write access anywhere
Guest	Contractors, partners	Specific shared resources only	No internal network access

4.3 Privileged Identity Management (PIM)

- Administrator roles are not permanently assigned — they use Entra PIM for just-in-time (JIT) access. This means admins have standard user accounts by default and must explicitly activate elevated privileges when needed:
 - Activation requires: MFA re-authentication + business justification + approval from security manager
 - Maximum activation duration: 4 hours — role automatically expires after this period
 - All activations logged: full audit trail including justification, approver, and actions taken during session
 - Global Admin role: activation requires approval from two security managers + CISO notification
 - Emergency access: two break-glass accounts with permanent Global Admin — stored in physical safe, usage triggers immediate security alert

```
# PIM policy - IT Admin role example
Role: IT Administrator
Assignment type: Eligible (not permanent)
Max activation duration: 4 hours
Require MFA on activation: Yes
Require justification: Yes
Require approval: Yes
Approvers: Security Manager (primary), IT Director (backup)
Notification on activation: Security team email + SIEM alert
```

4.4 Access Review Process

Quarterly access reviews are automated via Entra Access Reviews. The process runs every 90 days:

Step	Action	Responsible	Outcome if no response
1	Access review initiated automatically	Entra ID (automated)	—
2	Managers notified — review direct reports' access	Department managers	—
3	Manager approves or denies each role assignment	Department managers	14-day reminder sent
4	No response after 14 days — auto-deny applied	Entra ID (automated)	Role removed automatically
5	Security team reviews IT and admin role assignments	Security Admin	Escalated if no response
6	Report generated — exceptions flagged for investigation	Security Admin	—

4.5 Onboarding and Offboarding

Onboarding

- IT creates account with Standard User role only — no elevated permissions at creation
- Manager submits access request form specifying required roles for the job function
- Security team reviews request — approves or requests justification for any role above Standard User
- MFA registration required within 24 hours — account restricted until complete

Offboarding

- Account disabled within 1 hour of departure confirmation — not deleted, disabled for 30-day audit period
- All role assignments removed immediately on account disable
- Active sessions revoked — Entra ID sign-out from all devices and applications
- VPN certificates and FIDO2 key registrations revoked
- Account deleted after 30-day audit period — manager notified to transfer owned files first

5. Password Policy

Parameter	Policy
Minimum length	• 14 characters (standard users) • 20 characters (admins)
Complexity	• Must include uppercase • Lowercase • Number • And symbol
Password history	• 24 passwords remembered ○ cannot reuse
Expiry	• No forced expiry (NIST SP 800-63B guidance) ○ change only on suspected compromise
Banned passwords	• Microsoft Entra banned password list • custom GlobalTech list ○ company name ○ product names ○ common patterns
Account lockout	• 5 failed attempts ○ 30-minute lockout ○ security team alerted at 10 failed attempts
Password manager	• Approved: ○ Bitwarden (corporate instance) ■ use encouraged for all accounts

6. Testing and Verification

Test	Method	Expected result
MFA prompt on sign-in	Sign in as standard user	MFA prompt appears — access denied without completing MFA
Legacy auth block	Attempt SMTP auth with username/password	Connection rejected — legacy auth blocked
Admin FIDO2 enforcement	Sign in as admin with TOTP instead of FIDO2	Denied — FIDO2 required for admin accounts
PIM activation	Request IT Admin role via PIM	Approval request sent — role active only after approval + MFA
Finance system — standard user	Attempt to access Finance app as Standard User	Access denied — role does not include Finance permission
Finance system — Finance user	Access Finance app as Finance User	Permitted — role grants access, FIDO2 + compliant device required
Offboarding — account disable	Disable test account, attempt sign-in	Sign-in blocked immediately — all sessions revoked
Access review — auto-deny	Simulate no manager response in review	Role removed automatically after 14 days

7. Maintenance Schedule

Task	Frequency
Review Entra ID sign-in logs — identify failed MFA and suspicious sign-ins	Daily
Review PIM activation logs — verify justifications are appropriate	Weekly
Check for accounts with MFA not registered	Weekly
Run access review cycle — all role assignments	Quarterly (every 90 days)
Audit service account permissions — ensure least privilege	Quarterly
Review and update banned password list	Every 6 months
Test break-glass account access — verify emergency access works	Every 6 months
Review conditional access policies against current threat landscape	Annually

8. Summary

- The IAM configuration for GlobalTech Corp remediates both authentication and privilege management findings from the assessment. The controls now in place are:
 - MFA mandatory for all ~580 accounts
 - Microsoft Authenticator (standard)
 - TOTP (privileged)
 - FIDO2 YubiKey (admins)
 - 7 conditional access policies
 - MFA enforcement
 - legacy auth block
 - high-risk sign-in blocking
 - Finance system restrictions
 - RBAC with 8 defined roles
 - all permissions granted through roles
 - no direct user assignments
 - PIM for all admin roles
 - just-in-time access
 - 4-hour maximum
 - dual-approval for Global Admin
 - Quarterly automated access reviews
 - auto-deny on no response
 - full audit trail
 - Structured onboarding/offboarding
 - account disabled within 1 hour of departure
 - All 8 test scenarios verified
 - MFA prompts, PIM activation, role restrictions, auto-deny